

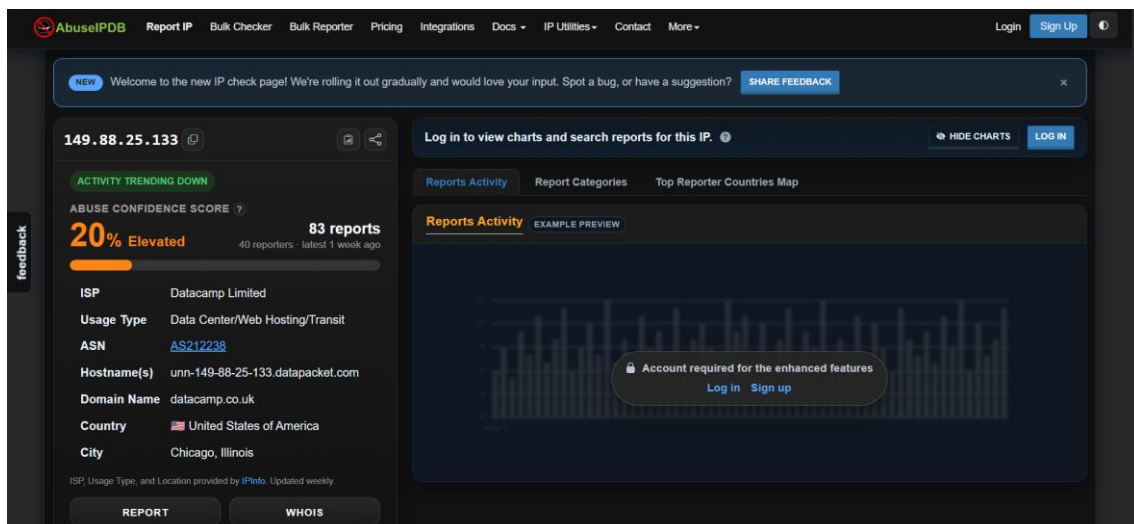
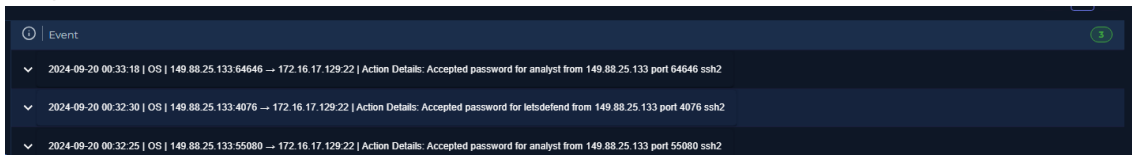
BruteForce - Sudoers File Modification Detected

LI Note :	Minutes before the alert, I saw a Brute Force attempt with different users from the IP 149.88.25.133 towards the system. However, I could not determine whether this attack was successful or not.
Hostname :	Kristine
Ip Address :	172.16.17.129
Command Line :	sudo cat /etc/sudoers
Trigger Reason :	Accessing the /etc/sudoers file is often a precursor to abusing the sudo mechanism itself, allowing attackers to run commands with elevated privileges.

Filtrando nos logs pelo IP suspeito é possível identificar várias tentativas de login em um curto período de tempo e em contas diferentes



Filtrando mais um pouco é possível identificar que 2 contas foram acessadas por esse IP suspeito



Verificando a reputação do IP ele foi dado como suspeito

Indo ao EDR:

EVENT TIME	COMMAND LINE
2024-09-20 06:36:22	getent passwd
2024-09-20 06:36:13	groups letsdefend1
2024-09-20 06:36:03	sudo cat /etc/sudoers
2024-09-20 06:35:26	sudo visudo
2024-09-20 06:35:12	sudo cat /etc/sudoers
2024-09-20 06:34:57	sudo -l
2024-09-20 06:34:32	sudo passwd letsdefend1
2024-09-20 06:34:24	sudo useradd -m letsdefend1
2024-09-20 06:33:48	whoami

No EDR é possível identificar uma sequência de comandos, onde ele cria um usuário novo, verifica suas permissões de sudo, altera o arquivo sudoers, provavelmente adicionando o novo usuário, verifica o usuário criado com groups e getent passwd para enumerar as contas cadastradas no sistema.

Checando:

```
root@ip-172-31-47-197:/home# cat analyst/.bash_history
whoami
groups analyst
sudo su
root@ip-172-31-47-197:/home# ls
analyst letsdefend letsdefend1 root ubuntu
root@ip-172-31-47-197:/home# hostory
hostory: command not found
root@ip-172-31-47-197:/home# history
1 2024-09-20 06:33:48 whoami
2 2024-09-20 06:34:24 sudo useradd -m letsdefend1
3 2024-09-20 06:34:32 sudo passwd letsdefend1
4 2024-09-20 06:34:57 sudo -l
5 2024-09-20 06:35:12 sudo cat /etc/sudoers
6 2024-09-20 06:35:26 sudo visudo
7 2024-09-20 06:36:03 sudo cat /etc/sudoers
8 2024-09-20 06:36:13 groups letsdefend1
9 2024-09-20 06:36:22 getent passwd
```

Cat /etc/passwd:

```
gnome-initial-setup:x:128:65534:./run/gnome-initial-setup:/bin/false
speech-dispatcher:x:129:29:Speech Dispatcher,,./run/speech-dispatcher:/bin/false
nm-openvpn:x:130:136:NetworkManager OpenVPN,,./var/lib/openvpn/chroot:/usr/sbin/nologin
hplip:x:131:7:HPLIP system user,,./run/hplip:/bin/false
letsdefend1:x:1003:1003:./home/letsdefend1:/bin/sh
```

Verificamos que o usuário foi realmente criado verificando o arquivo /etc/passwd

```
%sudo ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "#include" directives:

#includedir /etc/sudoers.d
$USER ALL=(ALL) NOPASSWD: ALL
analyst ALL=(ALL) NOPASSWD: ALL
letsdefend1 ALL=(ALL) NOPASSWD: ALL
```

Ele também conseguiu colocar o novo usuário com todas as permissões sudo no arquivo /etc/sudoers

É bom ver o que o outro usuário comprometido “letsdefend” fez também:

```

root@ip-172-31-45-116:~# cat /home/letsdefend/.bash_history
nano .bash_history
exit
ls
crontab -e
nano hello.txt
history
exit
root@ip-172-31-45-116:~#

root@ip-172-31-45-116:/home/letsdefend# crontab -l
# m h dom mon dow   command
@reboot sudo /usr/bin/vncserver :1
@reboot /usr/bin/websockify -D --web=/usr/share/novnc/ 433 localhost:5901
root@ip-172-31-45-116:/home/letsdefend#

```

Aparentemente foi criada uma tarefa agendada para abrir um VNC na porta 5901 sempre que a máquina for iniciada

IoCs:

Endereços IP:

- 149.88.25.133

Username criado:

- Letsdefend1

Arquivo alterado:

- /etc/sudoers

Tarefa agendada:

@reboot /usr/bin/websockify -D --web=/usr/share/novnc/ 433 localhost:5901

Vetor de Ataque:

Ssh exposto a internet, o atacante utilizou bruteforce e obteve sucesso nas contas letsdefend e analyst na máquina de IP 172.16.17.129

Análise:

O atacante obteve sucesso a duas contas no bruteforce, primeiro ele utilizou “whoami” para verificar quem ele era, depois criou a conta letsdefend1, verificou suas permissões sudo com “sudo -l”, verificando a conta ela estava com a permissão ALL:ALL, então ele conseguiu alterar o arquivo /etc/sudoers para dar permissão total para o letsdefend1 também, verificando também o histórico da conta letsdefend é possível observar que ele agendou uma tarefa, onde a porta 5901 com serviço VNC é aberta ao iniciar o host, tanto criar a conta quanto criar uma tarefa agendada são técnicas de persistência

Para evitar detecção ele utilizou a técnica **Abuse Elevation Control Mechanism (T1548)**.

O IP veio de uma rede externa e foi dado como suspeito por fontes como AbuseIPDB

Recomendações:

- Desabilitar e resetar as senhas das contas comprometidas
- Isolar a máquina da rede
- Bloquear IP malicioso
- Aplicar uma política de senhas forte

- Não expor serviços de conexão remota como SSH para a internet caso não for necessário